

TRAINING @ FORREST ONE

Session 9 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Endpoint, Application, Cloud & Virtualisation Security

Hardening the hosts, securing the code and defending the shared estate.

ENDPOINT

SECURE CODING

CLOUD

VIRTUALISATION

© Billy Forrest



WELCOME · WHERE WE ARE

Defence beyond the network

- **Session 8** secured the network boundary
- **Today** the hosts, the code and the cloud
- **The thread** every layer carries its own controls, none trusted alone
- **The exam line** pick the control for the asset, not the product



SESSION OBJECTIVES

By the end of this session you will be able to

- **Explain endpoint protection** hardening, EDR, app control
- **Describe mobile management** MDM, BYOD and mobile threats
- **Secure the SDLC** DevSecOps and secure coding
- **Describe app attacks** injection, XSS, CSRF
- **Explain cloud security** models, shared responsibility
- **Secure virtualisation** hypervisors, containers



TOPIC 9A · ENDPOINT SECURITY

Endpoint protection

- **The endpoint** any device that touches the network, whatever its role
- **Antivirus and EDR** signature detection plus behaviour monitoring
- **The gap** signatures miss unknown threats, behaviour catches them
- **The stack** AV/EDR, host firewall, hardening, patching, app control



TOPIC 9A · ENDPOINT SECURITY

Hardening the endpoint

- **Baseline** a documented secure configuration from a known state
- **Sources** CIS benchmarks and vendor hardening guides
- **Patch management** close the known holes first, then verify
- **Disable what you do not use** services, ports, default accounts
- **The test** would a default install fail your policy?



TOPIC 9A · ENDPOINT SECURITY

Application control

- **Allowlisting** only pre-approved software runs
- **Blocklisting** known bad software is denied
- **Code signing** verify origin and integrity before execution
- **The modern choice** allowlisting wins, blocklists miss unknowns
- **The benefit** malware cannot execute if it is not approved



TOPIC 9A · ENDPOINT SECURITY

Mobile device management

- **MDM** enrol, configure, enforce, wipe centrally
- **BYOD** personal devices carrying corporate data
- **Application vetting** assess, comply and check reputation before install
- **Containers** separate work and personal data on the device
- **The controls** remote wipe, encryption, jailbreak detection



QUIZ

Activity: secure the fleet

- A laptop runs an unknown executable: which control stops it?
- A manager's phone holds corporate mail: which model fits?
- Which device should never join the domain?
- Debrief: what is the one control every endpoint needs?

Allowlisting blocks unknown executables · MDM with containers fits BYOD · guest/IoT stays off the domain · patching is the baseline.



TOPIC 9A · ENDPOINT SECURITY

Operating system security

- **User accounts** least privilege, no admin by default
- **Secure boot** verified boot chain blocks tampered firmware
- **Full disk encryption** protects data at rest on lost media
- **Firmware updates** close hardware-level vulnerabilities
- **The habit** update, reboot, verify



DISCUSSION

Your AV never fired, yet a workstation was compromised. What went wrong?

Signatures miss zero-days. Behaviour monitoring, allowlisting and patching would have caught or prevented it.

Detection is a stack, not a single product; layer the controls.



BREAK
10 MINUTES

Back soon: the application lifecycle, secure coding and application attacks.



TOPIC 9B · THE LIFECYCLE

Security in the SDLC

- **Shift left** security from the first design, not the last test
- **Threat modelling** find the attack surface before code exists
- **Code review** human and automated checks at every change
- **Testing** SAST for source, DAST for running apps
- **Input validation** whitelisting, sanitisation and boundary checks



TOPIC 9B · THE LIFECYCLE

DevSecOps

- **The idea** security is part of the pipeline, not a gate
- **CI/CD** every build is scanned and tested automatically
- **Infrastructure as code** scan templates, manage secrets centrally
- **The failure mode** security bolted on at the end
- **The outcome** secure code ships as fast as insecure code



TOPIC 9C · APPLICATION ATTACKS

SQL injection

- **The flaw** user input treated as part of the query
- **The impact** read, modify or delete database data
- **The classic fix** parameterised queries, input is data not code
- **Input validation** whitelist, sanitise and bound every field
- **The test** any input field is a potential injection point



TOPIC 9C · APPLICATION ATTACKS

XSS and CSRF

- **XSS** attacker script runs in another user's browser
- **CSRF** forged request rides a victim's session
- **The fixes** output encoding, same-site cookies, tokens
- **Defence** a WAF filters and monitors web traffic
- **The difference** XSS hijacks the browser; CSRF hijacks the action



TOPIC 9C · APPLICATION ATTACKS

More application attacks

- **Buffer overflow** excess input overwrites memory
- **Directory traversal** dot dot slash escapes the web root
- **Race condition** timing gap between check and use
- **Sandboxing** isolate risky code to contain any compromise
- **The pattern** input validation and least privilege



QUIZ

Activity: find the flaw

- A login field accepts ' OR 1=1: which attack?
- A script tag appears in another user's browser: which attack?
- A forged form submission uses a logged-in session: which attack?
- Debrief: which two fixes cover most of these?

SQL injection · XSS · CSRF · parameterised queries and output encoding.



TOPIC 9D · CLOUD & VIRTUALISATION

Cloud deployment and service models

Model	What it means
IaaS	VMs, storage, network. You secure everything above the hypervisor
PaaS	Platform provided. You secure the app and its data
SaaS	Software delivered. The vendor secures nearly everything
Public / private / hybrid	Who owns and operates the infrastructure
Community cloud	Shared by organisations with common needs



TOPIC 9D · CLOUD & VIRTUALISATION

Shared responsibility

- **The vendor** secures the cloud, the infrastructure underneath
- **The customer** secures what is in the cloud, config, data, access
- **The line moves** IaaS you secure the guest; SaaS the vendor does more
- **Community cloud** responsibilities shared across members and provider
- **The exam line** misunderstanding the line is a failing answer



TOPIC 9D · CLOUD & VIRTUALISATION

Misconfiguration is the number one cloud risk

- **The cause** defaults, open buckets, permissive policies
- **The exposure** data leaks reachable from the internet
- **The tooling** CASB, posture management, policy as code
- **IaC guardrails** scan templates and check compliance automatically
- **The habit** assume misconfiguration until proven otherwise



TOPIC 9D · CLOUD & VIRTUALISATION

Securing the virtual estate

- **Hypervisor** separates the VMs, attack it and you own all
- **Type 1 vs Type 2** bare metal is smaller and safer than hosted
- **VM escape** breaking out of the guest into the host
- **Containers** share the kernel, isolate with namespaces and seccomp
- **The controls** patch the hypervisor, least privilege, network isolation



QUIZ

Check your understanding

- Open Quiz_Session_09.html in your browser.
- 20 questions, immediate feedback, topic tag on every question.
- Read each explanation: the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a session topic, e.g. 9C Application Attacks.



KEY TAKEAWAYS

- **Endpoints need a stack** AV/EDR, hardening, patching, app control.
- **Mobile is managed, not trusted** MDM, containers and remote wipe.
- **Secure code shifts left** threat modelling, review, SAST/DAST in the pipeline.
- **Injection is input as code** parameterised queries and output encoding.
- **Cloud is shared responsibility** you secure what is in the cloud, never assume.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Audit an app** find one input field and its validation
- **Map the responsibility line** for a SaaS and an IaaS you use
- **Classify the data** label a sample by type and state
- **Read ahead** Session 10, vulnerability management, resiliency and asset protection



NEXT SESSION

Session 10 — Vulnerability Management, Resiliency & Asset Protection

- Scanning, CVSS and prioritisation
- Patching, compensating controls and disclosure
- Backups, redundancy and site security

